

Řízení rizik třetích stran

Leden 2025

Zpracoval: Štefan Lesňák Funkce: Manager pro řízení rizik Dne: Leden 2025	Podpis:
Schválil: Mgr. Karel Waisser Funkce: Generální ředitel Dne: Leden 2025	Podpis:
Administrátor: Mgr. Martin Bakajsa Funkce: Vedoucí právního a compliance	Platnost od: 01.01.2025

Obsah:

1. Účel.....	3
2. Oblast platnosti.....	3
3. Zkratky a definice	3
4. Související dokumentace.....	4
5. Řízení rizik třetích stran	4
5.1. Úvod	4
5.2. Klíčové cíle investiční strategie	6
5.1. Materialita a určení významnosti.....	7
5.2. Zapojení zaměstnanců do řízení rizik třetích stran	7
5.3. Identifikace rizik spojených s třetími stranami	10
5.4. Proces výběru dodavatele.....	12
5.5. Smluvní dohody a požadavky	13
5.6. Monitoring a reporting rizika.....	13
5.7. Odpovědnosti v oblasti investic	15
5.7.1. Představenstvo.....	15
5.7.2. Manažer pro řízení rizik	15
5.7.3. Sponzor dodavatele.....	15
5.7.4. Compliance (zajišťování shody s předpisy).....	15
5.7.5. Vnitřní audit	16
6. Přehled záznamů	16
7. Provedené změny	16
8. Přílohy	16

1. Účel

Účelem této interní směrnice je stanovení strategie, pravidel a procesních postupů pro řízení rizik spojených se třetími stranami ve společnosti Slavia pojišťovna a.s. (dále jen „Slavia pojišťovna“ nebo „Pojišťovna“) tak, aby byly v souladu se zásadami řízení rizik a s rizikovým apetitem Pojišťovny.

Směrnice vychází z požadavků na řízení rizik stanovených obecně platnými právními předpisy pro oblast pojišťovnictví.

Tato pracovní instrukce slouží jako rozšíření směrnice OS 16 Pravidla Outsorcingu.

2. Oblast platnosti

Tato směrnice je závazná pro všechny osoby v pracovním nebo obdobném poměru ke společnosti Slavia pojišťovna (dále jen „zaměstnanci“) a pro společnosti poskytující externí poradenství na základě smlouvy. Za aktualizaci této směrnice odpovídá Manažer pro řízení rizik.

Přiměřenost a aktuálnost ustanovení této směrnice musí být Manažerem pro řízení rizik pravidelně kontrolována minimálně jedenkrát za 12 měsíců. Každá významná změna vyžaduje schválení od Představenstva.

3. Zkratky a definice

„poskytovatelem služeb IKT z řad třetích stran“ podnik poskytující služby IKT;

„službami IKT“ digitální a datové služby poskytované prostřednictvím systémů IKT průběžně jednomu nebo více interním nebo externím uživatelům, včetně hardwaru jako služby a hardwarových služeb, které zahrnují poskytování technické podpory prostřednictvím aktualizací softwaru nebo firmwaru poskytovatelem hardwaru, s výjimkou tradičních analogových telefonních služeb;

„zásadní nebo důležitou funkci“ funkce, jejíž narušení by významně narušilo finanční výkonnost finančního subjektu nebo řádný průběh nebo kontinuitu jeho služeb a činností nebo jejíž přerušení či chybný nebo neúspěšný průběh by významně narušily dodržování podmínek a povinností finančního subjektu vyplývajících z jeho povolení nebo jeho dalších povinností na základě platného práva v oblasti finančních služeb;

„kritickým poskytovatelem služeb IKT z řad třetích stran“ poskytovatel služeb IKT z řad třetích stran určený jako kritický v souladu s článkem 31 NAŘÍZENÍ EVROPSKÉHO PARLAMENTU A RADY (EU) 2022/2554

Registr informací: dle **ROVÁDĚCÍ NAŘÍZENÍ KOMISE (EU) 2024/2956**

ze dne 29. listopadu 2024,

kterým se stanoví prováděcí technické normy pro uplatňování nařízení Evropského parlamentu a Rady (EU) 2022/2554, pokud jde o standardní vzory pro registr informací

Vlastník smlouvy je spoznor dodavatele.

4. Související dokumentace

Interní dokumentace:

Organizační směrnice OS 16 Pravidla Outsorcingu

5. Řízení rizik třetích stran

5.1. Úvod

Tato směrnice stanovuje strategii, pravidla a procesní postupy pro řízení rizik vyplývajících ze vztahů se třetími stranami ve společnosti Slavia pojišťovna a.s. (dále jen „Slavia pojišťovna“ nebo „Pojišťovna“). Cílem směrnice je zajistit efektivní identifikaci, hodnocení, řízení a monitorování rizik spojených s poskytovateli služeb, dodavateli, outsourcingovými partnery a dalšími externími subjekty, se kterými Pojišťovna spolupracuje. Směrnice je navržena tak, aby byla v souladu s regulačními požadavky a osvědčenými postupy v oblasti řízení rizik.

Směrnice vychází z následujících právních a normativních rámců, které stanovují požadavky na řízení rizik třetích stran:

- Směrnice Solvency II (2009/138/ES) – požadavky na řízení rizik v pojišťovníctví, včetně outsourcingu a operační odolnosti.
- Normy ISO 27000 – zásady řízení informační bezpečnosti, ochrany dat a řízení bezpečnostních rizik spojených se třetími stranami.
- Nařízení DORA (Digital Operational Resilience Act, 2022/2554) – specifické požadavky na digitální operační odolnost včetně řízení ICT rizik spojených s externími dodavateli.

Tato směrnice se vztahuje na všechny třetí strany, se kterými Pojišťovna spolupracuje a které mohou mít přímý nebo nepřímý dopad na její provoz, včetně:

- Poskytovatelů IT služeb a cloudových řešení.
- Outsourcingových partnerů pro klíčové podnikové procesy.
- Poradců, auditorů a dalších dodavatelů odborných služeb.
- Strategických partnerů a dodavatelů infrastrukturních řešení.

- Jakýchkoli dalších subjektů, jejichž činnost může ovlivnit finanční stabilitu, reputaci, regulatorní soulad nebo provozní kontinuitu Pojišťovny.

Tato směrnice je závazná pro všechny útvary Pojišťovny, které vstupují do smluvních vztahů se třetími stranami, a tvoří základní rámec pro řízení souvisejících rizik v souladu s nejlepšími tržními a regulatorními standardy.

5.2. Klíčové cíle řízení rizik třetích stran

Identifikace a hodnocení rizik

Cílem je systematicky identifikovat a analyzovat rizika spojená se spoluprací se třetími stranami. Pojišťovna zavádí strukturovaný proces hodnocení rizik, který zahrnuje analýzu finanční stability, provozní odolnosti, regulatorního souladu a kybernetické bezpečnosti partnerů.

Snižování a řízení rizik

Pojišťovna přijímá opatření k minimalizaci identifikovaných rizik prostřednictvím vhodných smluvních ustanovení, bezpečnostních opatření a kontrolních mechanismů. Součástí řízení rizik je také stanovení mitigujících strategií a plánů reakce na incidenty.

Monitorování a auditování

Pojišťovna pravidelně monitoruje výkonnost a rizikový profil třetích stran, provádí interní a externí audity a zajišťuje kontinuální hodnocení souladu se smluvními a regulatorními požadavky.

Ochrana dat a bezpečnost

Klíčovým cílem je zajištění ochrany citlivých informací a osobních údajů v souladu s platnými legislativními a normativními standardy. Pojišťovna zavádí bezpečnostní opatření, jako jsou šifrování, přístupové kontroly a pravidelná školení zaměstnanců.

Kontinuita podnikání a krizové řízení

Pojišťovna integruje řízení rizik třetích stran do svého plánu kontinuity podnikání. To zahrnuje přípravu na krizové situace, testování plánů obnovy a zajištění alternativních poskytovatelů služeb v případě selhání stávajících partnerů nebo ukončení spolupráce.

5.3. Materialita a určení významnosti

Dopad do vlastního kapitálu přesahující 4 % jeho současné výše lze považovat za významný, a proto takto vymezujeme materialitu pro potřebu řízení rizik třetích stran.

Dodavatel je považován za významného vždy v případě, když maximální možný dopad do vlastního kapitálu v případě realizaci rizik spojených dodavatelem překročí úroveň materiality. Za posouzení významnosti dodavatele je odpovědná Osoba odpovědná za daného dodavatele na základě analýzy rizik spojených s dodavatelem.

5.4. Zapojení zaměstnanců do řízení rizik třetích stran

Kvalita a efektivita systému řízení rizik závisí zejména na schopnosti včasné identifikace rizik, jejich pochopení, kvantifikaci či ohodnocení těchto rizik, jejich průběžném řízení a následném pravidelném monitoringu a reportingu příslušným statutárním orgánům a zaměstnancům společnosti.

Neméně důležité je i organizační ukotvení řízení rizik s odpovídající definicí odpovědností a nastavením veškerých procesů souvisejících s řízením rizik.

Zapojení zaměstnanců Pojišťovny do řízení rizik je prezentováno aplikací tří linií obrany. Cílem této struktury je jasně definovat odpovědnosti a kontrolní činnosti v rámci řízení rizik a zároveň se vyvarovat potenciálnímu střetu zájmů.

První linie obrany

První linie obrany představuje operativní řízení rizik třetích stran v rámci jednotlivých oddělení Pojišťovny. Zodpovědné pracovní pozice:

Vedoucí oddělení/ředitel úseku/ Osoba odpovědná za outsourcing/ Sponzor ICT dodavatele – odpovědnost za implementaci opatření a řízení rizik na provozní úrovni.

Osoba pověřená řízením outsourcingu (Compliance Officer) – Poskytuje vedoucím zaměstnancům / osobám odpovědným za dílčí outsourcované činnosti metodickou podporu při výběrovém řízení a přípravě nebo připomínkování smlouvy s poskytovatelem. Specialista na bezpečnost – řízení technologických a kybernetických rizik spojených s externími partnery.

Druhá linie obrany

Manažer pro řízení rizik a Compliance tvoří druhou linii obrany. Druhá linie obrany je odpovědná za koordinaci a dohled nad efektivitou a celistvostí rámce řízení rizik třetích stran. Druhá linie obrany navrhuje limity v souladu s rizikovým apetitem Pojišťovny, které následně předkládá ke schválení Představenstvu. Manažer pro řízení rizik pravidelně kontroluje plnění limitů. Výsledky každé kontroly předkládá výboru pro řízení rizik, která materiály vyhodnotí a předá Představenstvu Pojišťovny.

Současně je druhá linie obrany odpovědná za navržení eskalačního procesu.

Pojišťovna uznává význam úzké spolupráce mezi první a druhou linií obrany v oblasti řízení rizik, včetně poskytování metodické podpory a vzdělávání první linie ze strany druhé linie obrany. Aby bylo zajištěno, že tato spolupráce probíhá v souladu s principy nezávislé kontroly a aby se předešlo možnému střetu zájmů, jsou zavedeny následující opatření:

- Organizační oddělení a nezávislost kontrolní funkce: Druhá linie obrany je organizačně oddělena od první linie obrany a nezávislá na jejích rozhodovacích procesech. Toto oddělení zajišťuje, že druhá linie obrany může vykonávat svou kontrolní funkci objektivně a bez vlivu ze strany první linie.
- Eskalační proces a řízení rizik: Druhá linie obrany je odpovědná za návrh a dohled nad eskalačním procesem v oblasti rizik, přičemž tento proces zajišťuje, že veškeré závažné rizikové situace jsou okamžitě eskalovány na vyšší úroveň řízení, včetně případného zapojení nejvyššího vedení pojišťovny. Eskalační proces zahrnuje mechanismy pro zajištění nezávislého přezkumu rizikových situací.
- Metodická podpora a vzdělávání: Druhá linie obrany poskytuje metodickou podporu a vzdělávání první linii v oblasti řízení investičních rizik, nicméně tato činnost nezasahuje do každodenního řízení investičních portfolií, které je plně v kompetenci první linie obrany. Vzdělávací aktivity jsou navrženy tak, aby podporovaly zlepšení odborné způsobilosti první linie obrany, aniž by to narušilo nezávislou kontrolní funkci druhé linie.
- Předcházení střetu zájmů: Aby bylo předejito případnému střetu zájmů, každé rozhodnutí druhé linie obrany týkající se metodické podpory nebo poradenství v oblasti rizik je systematicky přezkoumáváno výborem řízení rizik. Tento přezkum zajišťuje, že druhá linie obrany nepřevádí svou kontrolní funkci na první linii a zachovává svou nezávislost.
- Pravidelné hodnocení a audit: Kontrolní postupy druhé linie obrany, včetně její spolupráce s první linií, podléhají pravidelnému internímu auditu. Tento audit hodnotí nezávislost druhé linie obrany a její schopnost efektivně plnit svou kontrolní funkci bez střetu zájmů.

Tato opatření zajišťují, že druhá linie obrany může nadále efektivně poskytovat podporu první linii obrany, aniž by tím byla ohrožena její nezávislost nebo role při zajištění kontrolní funkce.

Třetí linie obrany

Třetí linie obrany je zajištěna interním auditem, který vykonává nezávislé a objektivní přezkoumávání a vyhodnocování přiměřenosti, efektivnosti a účinnosti vnitřního kontrolního systému v oblasti řízení rizik třetích stran.

Interní audit nesmí vykonávat činnosti, které by mohly narušit jeho nezávislost, a jeho role je striktně oddělena od druhé linie obrany, která zahrnuje nastavení pravidel, limitů a jejich kontrolu. Třetí linie obrany se zaměřuje výhradně na přezkum a hodnocení těchto procesů, nikoli na jejich operativní kontrolu nebo implementaci.

Funkcí interního auditu je podporovat Představenstvo v identifikaci strategií a předpisů pro interní kontrolu a řízení rizik, podávat ujištění ohledně jejich přiměřenosti a platnosti a poskytovat Představenstvu analýzy, hodnocení, doporučení a informace týkající se prověřovaných činností.

V případě zjištěných nedostatků interní audit v písemné zprávě uvede jejich závažnost, včetně konkrétního návrhu nápravných opatření a lhůty pro jejich realizaci. Odpovědnost za řešení zjištěných nedostatků spočívá na Představenstvu Pojišťovny, interní audit odpovídá za sledování realizace nápravných opatření.

Nezávislost interního auditu

Aby byla zajištěna nezávislost a objektivita interního auditu jako třetí linie obrany, platí následující pravidla:

Interní audit nemůže být zapojen do operativních činností druhé linie obrany, jako je nastavování limitů či kontrola jejich dodržování.

Interní audit má plnou autonomii při plánování auditů, stanovení jejich rozsahu, postupech, frekvenci, časovém harmonogramu a obsahu zpráv.

Do činnosti interního auditu nesmí zasahovat žádná jiná organizační složka Pojišťovny.

Interní audit pravidelně posuzuje procesy řízení rizik třetích stran, včetně efektivnosti a včasnosti přenosu informací, přičemž jeho analýzy a hodnocení slouží jako podklad pro rozhodování Představenstva.

Interní audit identifikuje potenciálně zranitelná místa procesu a předkládá nezávislá doporučení na jejich eliminaci.

Frekvence auditu

Interní audit rizik třetích stran probíhá alespoň jednou za 3 roky, přičemž frekvence může být navýšena na základě rizikového profilu Pojišťovny nebo zjištěných nedostatků v minulém auditu. Každý audit je proveden tak, aby byly eliminovány možné konflikty zájmů mezi druhou a třetí linií obrany.

5.5. Identifikace rizik spojených s třetími stranami

Pojišťovna vystavena následujícím rizikům:

Regulační a právní rizika

- Nedodržení regulací (např. GDPR, DORA, Solvency II).
- Nejasné smluvní podmínky (nedostatečné SLA, chybějící odpovědnost za incidenty).
- Riziko outsourcingu do třetích zemí s nižší úrovní ochrany dat.

Informační bezpečnost a ochrana dat

- Neadekvátní bezpečnostní opatření u třetích stran.
- Riziko úniku citlivých nebo osobních údajů.
- Slabá ochrana přístupových práv a identit.

Riziko kybernetických útoků

- Zranitelnosti v systémech dodavatelů (malware, phishing, ransomware).
- Nedostatečné monitorování bezpečnostních událostí.
- Možnost kompromitace dodavatelského řetězce.

Rizika provozní kontinuity

- Závislost na dodavateli v kritických procesech.
- Nedostatečné plány obnovy (BCP/DRP).
- Možné výpadky služeb nebo infrastruktury.

Riziko kvality a výkonu služeb

- Nesplnění SLA a KPI dodavatelem.
- Špatná kvalita dodávaných služeb nebo produktů.
- Nedostatek flexibility při změnách požadavků.

Finanční rizika

- Platební neschopnost nebo bankrot dodavatele.
- Neprůhledné cenové modely a skryté náklady.
- Riziko finančního podvodu nebo nesprávného účetnictví.

Strategická a reputační rizika

- Negativní dopad na značku při porušení regulací dodavatelem.
- Etické problémy (korupce, porušení ESG principů).
- Nedostatek transparentnosti v dodavatelském řetězci.

Riziko řízení a kontroly třetích stran

- Slabá due diligence před uzavřením smlouvy.
- Nedostatečný dohled nad dodavatelem během spolupráce.
- Chybějící mechanismy auditů a kontrol.

Riziko technologické závislosti

- Lock-in efekt (závislost na jedné technologii nebo poskytovateli).
- Neaktuální nebo nekompatibilní IT systémy.
- Chybějící interoperabilita a přenositelnost dat.

Riziko lidského faktoru

- Závislost na klíčovém zaměstnancích dodavatele.
- Nedostatečná kvalifikace nebo školení pracovníků.
- Možnost interních hrozeb (insider threats) u třetích stran.

Koncentrace rizik:

Povinnost při identifikaci a posuzování rizik zhodnotit, zda by plánované uzavření smluvního ujednání souvisejícího se službami IKT podporujícími zásadní nebo důležité funkce způsobilo jakoukoli z těchto situací:

- uzavření smlouvy s poskytovatelem služeb z řad třetích stran, kterou není snadné nahradit
- uzavření více smluvních ujednání týkajících se poskytování služeb podporujících zásadní nebo důležité funkce se stejným poskytovatelem služeb z řad třetích stran nebo s úzce propojenými poskytovateli služeb z řad třetích stran.

Sponzor dodavatele zváží přínosy a náklady alternativních řešení, například využití jiných poskytovatelů služeb z řad třetích stran, přičemž zohlední, zda a jak předpokládaná řešení odpovídají požadavkům obchodní činnosti a cílům stanoveným v jejich strategii digitální odolnosti.

Rizika se identifikují s ohledem na následující hrozby:

- Významné narušení finanční výkonnosti Společnosti
- Významné narušení funkčnosti či dostupnosti poskytovaných služeb
- Významné porušení podmínek povolení k činnosti Společnosti
- Významné porušení obecně závazných právních předpisů upravujících činnost Společnosti
- Jiný závažný zásah do chráněných zájmů Společnosti, jejích vlastníků a klientů.

Sponzor dodavatele zajistí pravidelnou aktualizaci, kontrolu aktuálnosti a úplnosti identifikovaných rizik a zavedených opatření. U dodavatele, který byl identifikován jako významný 1x za rok, u ostatních nejméně 1x za 3 roky.

Sponzor dodavatele před uzavřením smlouvy o plnění s dodavatelem identifikuje a vyhodnotí rizika spojená s dodavatelem a poskytovanou službou.

Sponzor dodavatele je povinen zajistit kontrolu aktuálnosti a úplnosti identifikovaných rizik a zavedených opatření i v případě výskytu významného provozního či bezpečnostního incidentu, který byl, byť částečně, způsoben dodavatelem, stejně jako v případě identifikace nových externích hrozeb souvisejících s daným procesem.

Sponzor dodavatele zajistí ověření dodavatele zejména prostřednictvím ověření veřejně dostupných informací (obchodní rejstřík, výroční zprávy, reputace atd.) a kontrolního dotazníku a jeho vyhodnocení. Při vyhodnocení si může vyžádat odborné stanovisko dalších útvarů Společnosti. Výstupem z hodnocení je součástí podkladů pro výbor pro řízení rizik, který dává doporučení vedení Společnosti o využití služeb dodavatele.

Sponzor dodavatele aktualizuje hodnocení u dodavatele podporujícího zásadní nebo důležitou funkci nejméně 1x za 1 roky, u ostatních nejméně 1x za 3 roky. Sponzor dodavatele je také povinen revidovat hodnocení dodavatele při zjištění nových skutečností, které by mohly mít dopad na poskytování služeb.

Sponzor dodavatele zajistí, aby u dodavatelů podporujících zásadní nebo důležité funkce byla zpracována exit strategie.

Cílem exit strategie je definovat konkrétní kroky a odpovědnosti při Společnosti odchodu od dodavatele tak, aby nedošlo k narušení poskytovaných služeb či plnění právních či regulatorních povinností.

Sponzor dodavatele zajistí, aby u dodavatelů podporujících zásadní nebo důležité funkce bylo vyhodnoceno, jak by jejich výpadek zasáhl do dostupnosti a odolnosti podporovaných funkcí.

V případě, že by výpadek dodavatele představoval riziko výpadku daného procesu na dobu delší než 24 hodin, nebo zásah do integrity, důvěrnosti, autenticity či dostupnosti dat, která jsou v daném procesu zpracovávána, je Sponzor dodavatele povinen připravit havarijní plán pro výpadek dodavatele tak, aby dopad na zásadní nebo důležité funkce byl pro Společnost akceptovatelný.

Havarijní plán pro výpadek významného dodavatele musí být součástí širších business continuity procesů a dokumentů.

5.6. Proces výběru dodavatele

Sponzor dodavatele je odpovědný, že v rámci výběrového řízení ověří, zda zvolený dodavatel poskytuje dostatečné záruky za technickou, provozní, expertní a finanční schopnost poskytovat dané služby a plnit smluvní ujednání.

Sponzor dodavatele při jeho výběru rovněž zohlední další kritéria důležitá pro ochranu zájmů Společnosti, zajištění bezpečnosti a odolnosti poskytovaných služeb a plnění regulatorních povinností, zejména:

- Finanční situace dodavatele: Společnost musí posoudit finanční situaci ICT dodavatele, aby se ujistila, že je schopen splnit své závazky.
- Technické dovednosti dodavatele: Společnost musí posoudit technické dovednosti dodavatele, aby se ujistila, že je schopen poskytnout služby v požadované kvalitě.

- Kapacity dodavatele: Společnost musí posoudit a vhodným způsobem zajistit, aby dodavatel disponoval dostatečnými kapacitami pro poskytování sjednaných služeb ve sjednané kvalitě.
- Vnitřní řízení dodavatele: Společnost musí posoudit, zda má dodavatel zavedena nezbytná opatření pro vnitřní řízení a kontrolu nezbytné k poskytování sjednané služby.
- Naplnění bezpečnostních požadavků: Společnost musí posoudit schopnost dodavatele naplnit její bezpečnostních požadavků, aby zajistila dostatečnou míru bezpečnosti a odolnosti svých činností a poskytovaných služeb.
- Reputace dodavatele: Společnost vhodným způsobem ověří, zda využití konkrétního dodavatele nepředstavuje závažné reputační riziko.

5.7. Smluvní dohody a požadavky

Sponzor ICT dodavatele nad rámec OS 16 Pravidla outsourcingu zajistí, že smlouva s ICT dodavatelem bude dostatečně jasně a konkrétně a s přihlédnutím k poskytovaným službám upravovat následující práva a povinnosti všech smluvních stran.

Dle DORA_dodatek_NEvyznamna_sluzba a DORA_dodatek_vyznamna_sluzba a OS 16 pravidla outsourcingu.

5.8. Monitoring a reporting rizika

Sponzor dodavatele nebo jím určený zaměstnanec je odpovědný za průběžné hodnocení dodávek, jejich souladu se smluvním ujednáním a požadavky obecně závazných právních předpisů. V případě zjištění závažných nedostatků je Sponzor dodavatele povinen bezodkladně přijmout nezbytné kroky k ochraně práv Společnosti, například přípravu dodatku ke smlouvě, upřesnění procesu spolupráce s ICT dodavatelem, zahájení exit strategie atd.

Sponzor dodavatele zajistí, aktualizaci dokumentace dle této politiky u ICT dodavatele podporujícího zásadní nebo důležitou funkci nejméně 1x za 1 rok, u ostatních nejméně 1x za 3 roky.

Člen řídicího orgánu odpovědný za řádné a obezřetné řízení rizik poskytovatelů služeb a za kontrolu jejího dodržování ve Společnosti předloží jednou ročně vedení Společnosti zprávu o řízení dodavatelů, vypracovanou manažerem pro řízení rizik, která obsahuje alespoň:

Seznam využívaných dodavatelů s rozlišením, který z nich podporuje zásadní nebo důležité funkce ve Společnosti, a u každého z nich:

- Sponzora dodavatele

- Datum poslední revize dokumentace
- Závažné porušení smluvních ujednání nebo obecně závazných předpisů
- Závažné bezpečnostní nebo provozní incidenty způsobené ICT dodavatelem
- Hodnocení procesu řízení ICT dodavatelů, včetně případných návrhů na jejich aktualizaci

5.9. Odpovědnosti v oblasti řízení rizik třetích stran**5.9.1. Představenstvo**

Představenstvo ve vztahu k systému řízení rizik třetích stran:

- a) Nese konečnou odpovědnost za řízení rizik Pojišťovny.
- b) Definuje strategii řízení rizik a schvaluje odpovídající rizikový apetit.
- c) Řídí společnost v souladu s implementovanými strategiemi.
- d) Projednává a schvaluje materiály předložené výborem pro řízení rizik
- e) Je finálním rozhodovatelem v rámci eskalačních procesů a musí zajistit adekvátní odezvu na riziko nebo incident, aby nedošlo k poškození Pojišťovny.
- f) Odpovídá za posouzení a schválení základních zásad a postupů a přijatelné míry rizik předložených výborem pro řízení rizik

5.9.2. Manažer pro řízení rizik

Manažer pro řízení rizik je zaměstnanec odpovědný za řízení rizik. Manažer pro řízení rizik ve vztahu k systému řízení rizik třetích stran:

- a) Odpovídá za vytvoření, aktualizaci a správu procesu řízení rizik (včetně této směrnice) a zabezpečení všech aktivit definovaných touto směrnicí.
- b) Sestavuje pravidelně report (nejméně jednou za rok) o vývoji rizik třetích stran, který předkládá Výboru pro řízení rizik a Představenstvu.
- c) Dohlíží na dodržování interních limitů a v případě jejich překročení má povinnost neprodleně informovat výbor pro Řízení rizik s návrhem nápravných opatření.
- d) Pravidelně sleduje plnění nápravných opatření.

5.9.3. Sponzor dodavatele

Sponzor dodavatele ve vztahu k řízení rizik třetích stran:

- 1. má odpovědnost za smluvní vztah s externím subjektem
- 2. odpovídá za průkazné seznámení externích subjektů spolupracujících s Pojišťovnou s tímto předpisem na základě smluvních ujednání,
- 3. disponuje dostatečnými znalostmi a zkušenostmi v oblasti externě zajišťované činnosti.
- 4. analyzuje a kontroluje rozsah, úplnost a kvalitu dat zasílaných poskytovatelem služby
- 5. Sponzor ICT dodavatele je odpovědný za implementaci opatření a řízení rizik na provozní úrovni.
- 6. Odpovědnosti definované v kapitolách 5.3 – 5.7.

5.9.4. Compliance (zajišťování shody s předpisy)

Funkce Compliance ve vztahu k systému řízení rizik třetích stran:

- a) Zajišťuje, že je systém řízení rizik třetích stran je v souladu s právními předpisy a řídicím a kontrolním systémem Pojišťovny.
- b) Zajišťuje, že jsou organizační směrnice a související metodické pokyny vzájemně konzistentní a jsou v nich uvedeny relevantní informace.
- c) Průběžně sleduje vývoj právního prostředí a informuje Manažera pro řízení rizik a výbor pro řízení rizik o případných legislativních změnách, které se týkají řízení rizik třetích stran
- d) Poskytuje vedoucím zaměstnancům / osobám odpovědným za dílčí outsourcované činnosti metodickou podporu při výběrovém řízení a přípravě nebo připomínkování smlouvy s poskytovatelem.
- e) Odpovídá za udržování Registru informací o dodavatelích.

5.9.5. IT Manager a Security Manager

Dle PI-18_01 Řízení IKT rizik

5.9.6. Vnitřní audit

Vnitřní audit odpovídá ve vztahu k systému řízení rizik za:

- a) Nezávislé a objektivní přezkoumávání a vyhodnocování přiměřenosti, efektivnosti a účinnosti vnitřního kontrolního systému.
- b) Korektní postup během plnění svých úkolů v rámci interního auditu.
- c) Závěry z interních auditů, které předkládá a diskutuje s Představenstvem Pojišťovny.
- d) Sledování plnění nápravných opatření.

6. Přehled záznamů

Název záznamu	Místo uložení	Doba uložení	PC / papír	Poznámka

7. Provedené změny

Prvé úplné vydání dokumentu.

8. Přílohy
